IPSEC VPN ON FORTIGATE

Cybersecurity

WRITTEN BY

Cambell Xiao

Lab Purpose

This lab took place in a simulated environment in which an external host needs to remote-access to an internal host ensuring the access meets the CIA triad. An IPSEC VPN was to be configured and used when the host is attempting to remote desktop to the internal host. Through the usage of FortiGate's IPSEC client.

Background Information

When configuring any connection which can link an internal device to an external host, it is paramount to ensure that the connection meets CIA. CIA stands for Confidentiality, Integrity, and Availability. Information transmitted between the external host and the internal host needs to be Confidential, meaning the only two devices that should be able to access the data is the sending host and the receiving host. This also means all data in transit should be secure in the event of a breach. Data in transit is most likely to be encrypted with a secure protocol such as AES-256 for this purpose. Encrypting data means encoding data in a way that makes it completely indecipherable to an outsider's perspective looking in. It can take millions of years to decode this data using the average technology we have today because encryption algorithms can have very secure algorithms for encrypting the keys. For instance, RSA relies on using very large prime numbers to make it very difficult to decipher how to decode the data. This method of hiding data in plain sight is extremely effective, and often so effective that the algorithm for encrypting this data is posted in plain sight because it poses no actual function to decode the data. The sheer difficulty in factoring such a large number is what gives RSA its security.

The second rule of the CIA triad is integrity, meaning verification that each device's identity is verified. This is often done through the process of hashing data. Hashing works when using a hashing protocol such as SHA-256 to transform data into a fixed length. If any characters are edited during this process, even one word, the output of the hashing method will be a completely different hash.

For instance, I will hash the word "Cisco" using SHA-256 to get the output

"aa669b285cc133bf8440ce04e6c2559ed5ce8c77cab452d0152f0da9f3e21f89"

Next, I will hash the word "cisco" using SHA-256, with the only difference being a capitalization change. The result of this is

"e73b79a0b10f8cdb6ac7dbe4c0a5e25776e1148784b86cf98f7d6719d472af69"

As shown, the outputs are completely different. This means that all an endpoint needs to do is compare the received data with a hash of the expected data. If these hashes do not align, then it is very easy to tell that data has been tampered with.

The last but arguably most important part of the CIA Triad is Availability. Availability, as its name suggests, describes how often a service stays up and how accessible it is. This covers any traffic related issues such as having bottlenecked traffic or a critical device going down. This is often done through using multiple devices to form an active/standby role in which if one device goes down, another will be there to take its place. The biggest concern with availability is the device which the service runs on. The FortiGate Firewall may not be redundant or highly available on its own, but it is often recommended to apply failover plans in case of a hardware error.

Data is almost always in either of two states: Data at rest or data in transit. Data at rest refers to any data that is not moving and staying still. This means any data sitting in a hard drive at home or in a database in a corporation. Important data may be stored off-sight in a hard-drive in case of needing a backup. This data is much more secure than the former of the two: Data in transit. Data in transit refers to any data that is in motion, or actively being sent from a source to a destination. This means any data sent over a WIFI network in the local Starbucks or a download off an online website. Data in transit is much more vulnerable compared to Data at Rest because there are very many points in which the data can easily be intercepted by attackers running any packet sniffer tool such as Wireshark. Encryption is the method used to counteract this because even if the attackers were to gain access to the encrypted version of the data, it might take millions of years to create a brute-force solution to decrypt it. IPSEC is one of the most popular protocols for ensuring that the CIA triad is met, meeting all security standards for data in transit. It is done through using two authentication and encapsulation protocols: Authentication Header (AH) and Encapsulating Security Payload (ESP).

AH is a method that can be used in conjunction or on its own with ESP. It provides mostly integrity using a hash such as MD5 or SHA. A secret key is also generated during the data encapsulation process and checks if the secret of the sender matches with that of the receiver. While AH does not provide any data confidentiality at all, meaning it is very insecure when being used on its own, it can be used in conjunction with ESP to ensure all ends are met.

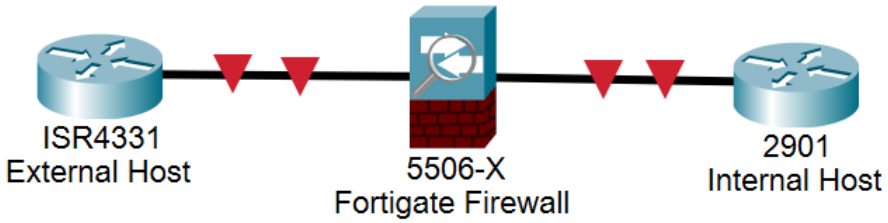
The purpose of ESP is to encrypt and authenticate any packets in transit of a VPN tunnel. This provides both confidentiality and integrity to IPSEC because not only is traffic encrypted, but an origin authentication algorithm is run to ensure that the source of the data is correct. This encryption is often done through an AES protocol such as AES-CCM or AES-GCM. ESP provides the bare minimum to send across the network with confidentiality and integrity without the usage of AH, but combining both protocols into one greatly enhances the integrity of any data sent, even if the encryption isn't any different.

These VPNs are to be configured in two different forwarding methods: tunneling and transport mode. In transport mode, the IPSEC VPN will directly forward all traffic as if it was in a point-to-point link with the destination. The data will be encrypted but no IP header will be added

which makes it difficult to use any sort of NAT. However, this provides great benefit when it is important to ensure there is very little overhead information and the network administrator is looking purely for a quick connection. For this reason, it is recommended to use transport mode as host-to-host connections for cases such as remote desktop.

Tunneling mode is often used when two networks are separated by an intermediary network which is untrusted. These are often configured as site-to-site VPNs. Tunneling mode completely provides all features of CIA listed above. It completely encrypts the original packet's IP header, making sure no private network information is leaked, then creates a new IP header on top of it when transversing the untrusted network. While this process is extremely secure, there are difficulties forwarding large amounts of information over this VPN along with much more overhead compared to a transport-mode VPN.

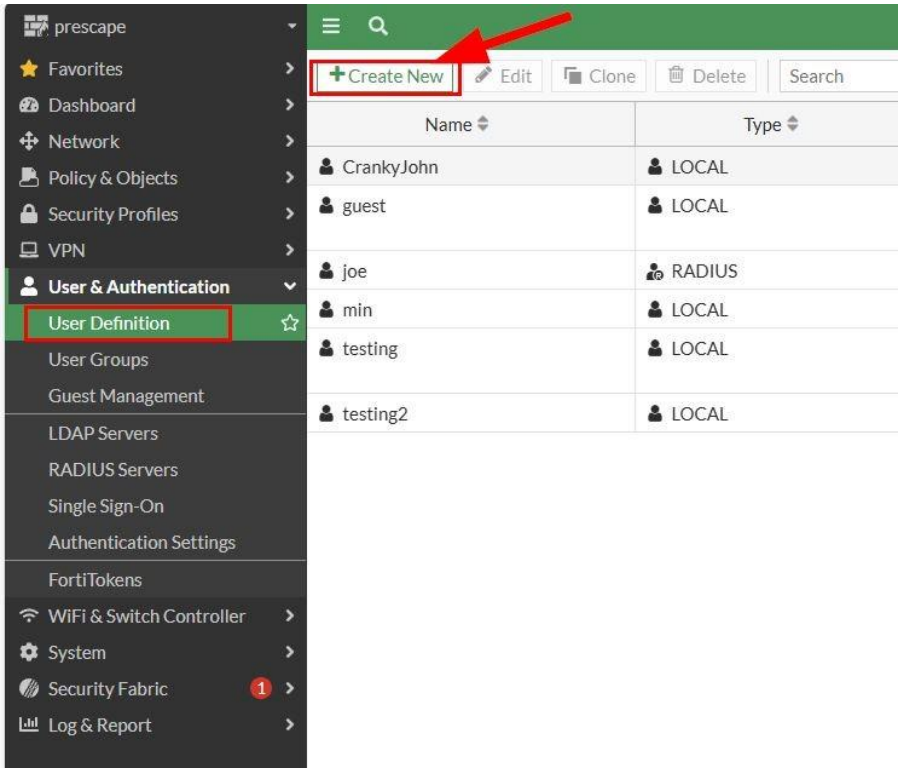
Topology



Lab Guide

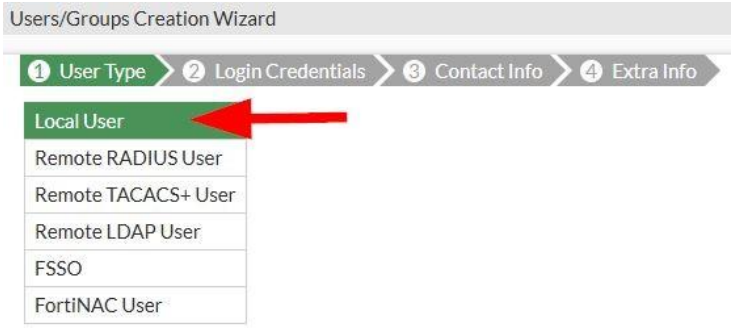
1.

Enter User & Authentication and select "Create New" to create a new user.



2.

Set the user as a Local User and then press Next.

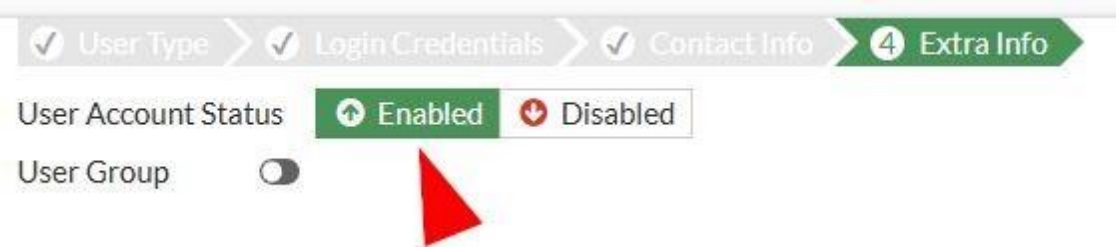


3.

Create a Username and Password for the user.

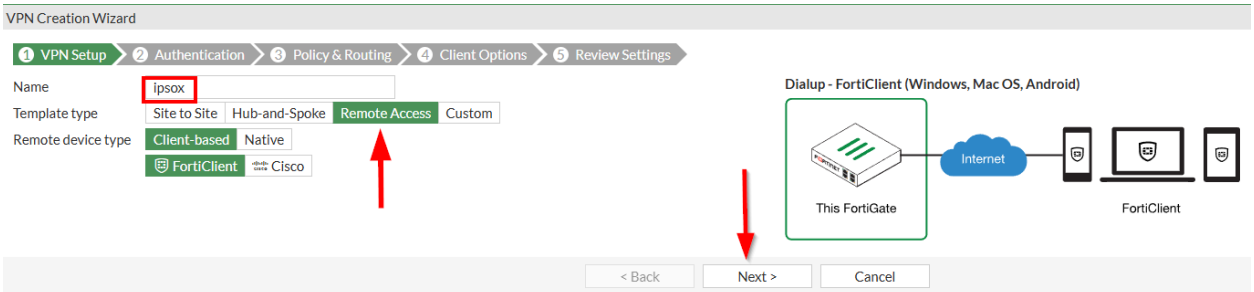
4.

Ensure that the User Account Status is enabled. Then finish the User Configuration.



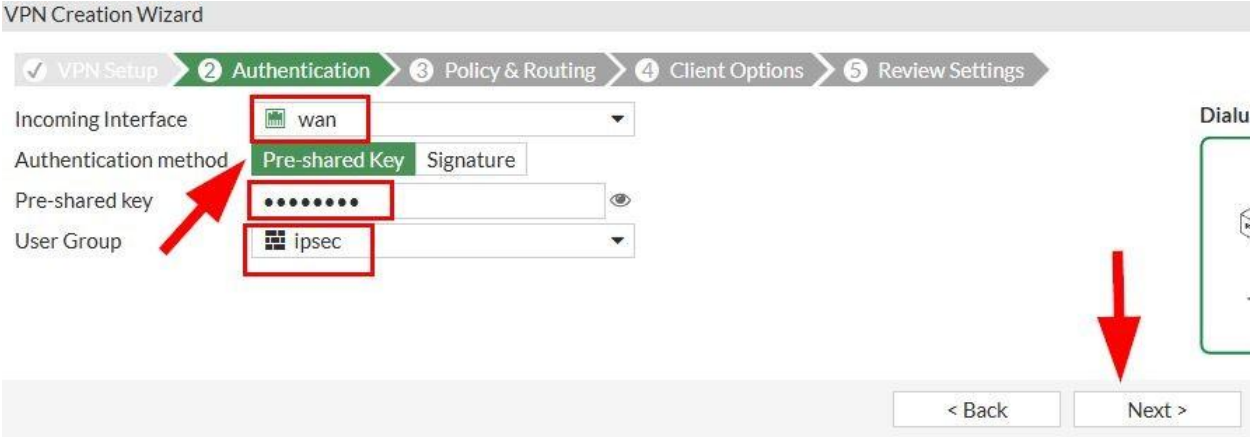
5.

Under VPN > VPN Wizard, Give the VPN a name and set the template to “Remote Access”. Ensure that the VPN will use FortiClient. Then press Next.



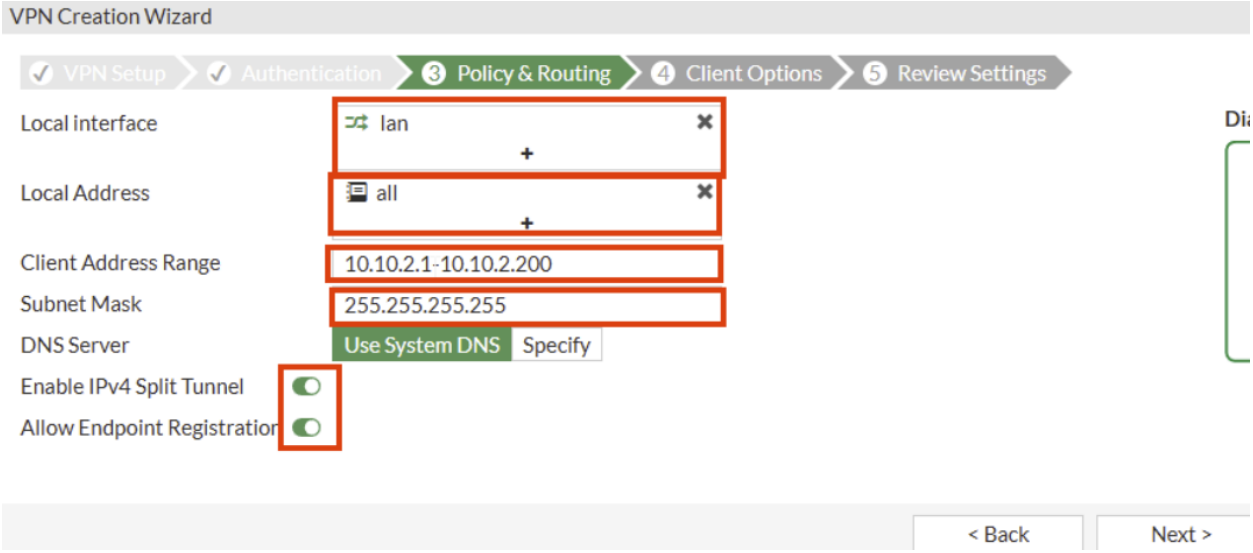
6.

Under Authentication, allow incoming connections from the WAN port of the firewall. Set the Authentication method to Pre-shared Key and then enter the Preshared key. Select the User-Group created earlier.



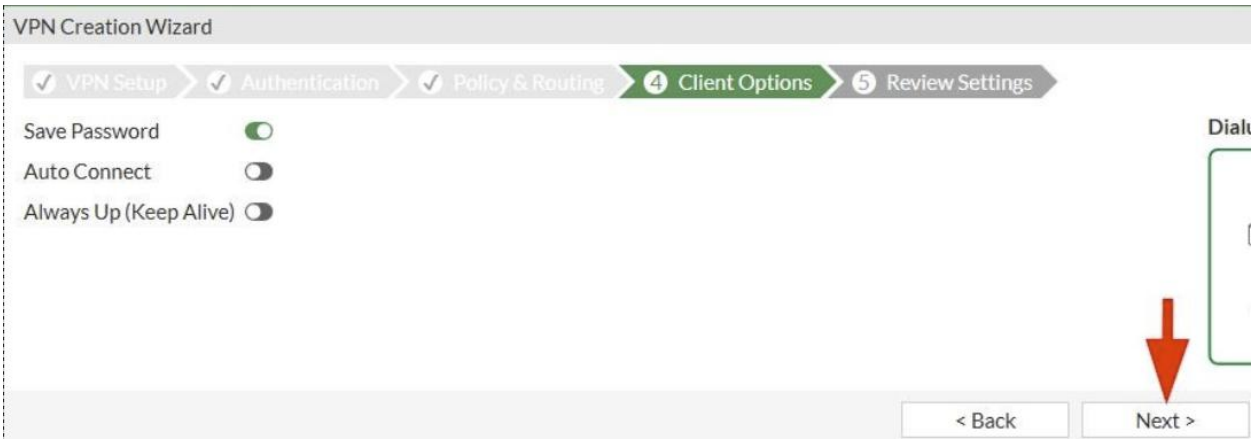
7.

Under Policy & Routing, set the Local Interface to LAN and the local addresses to all. Set a Client Address Range and the subnet mask. Enable Split tunneling and Endpoint registration.



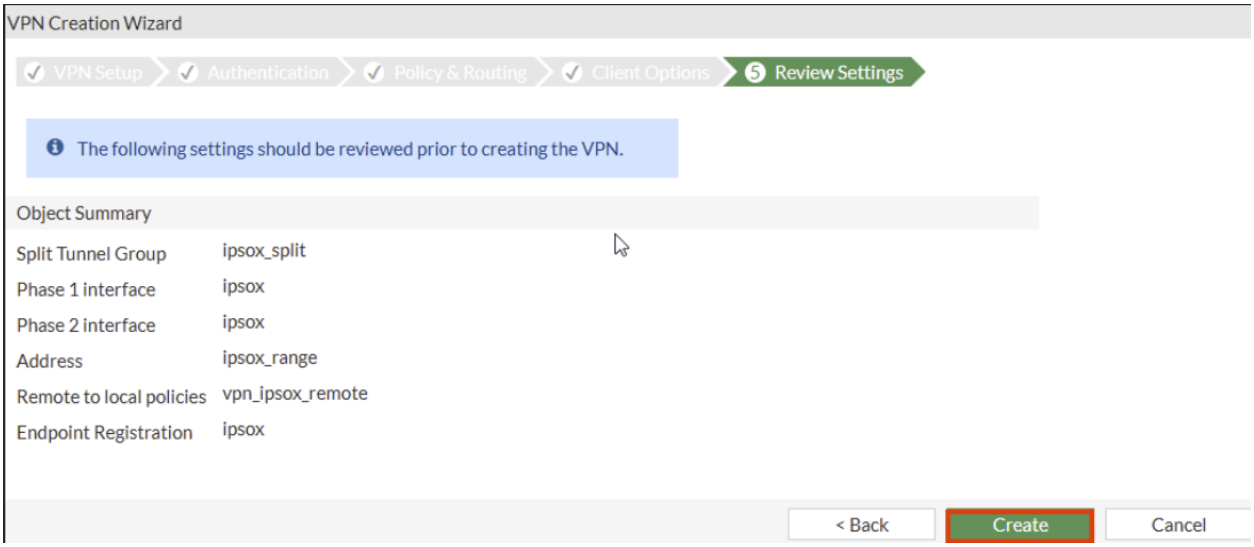
8.

Under Client Options, maintain the default settings and press Next.



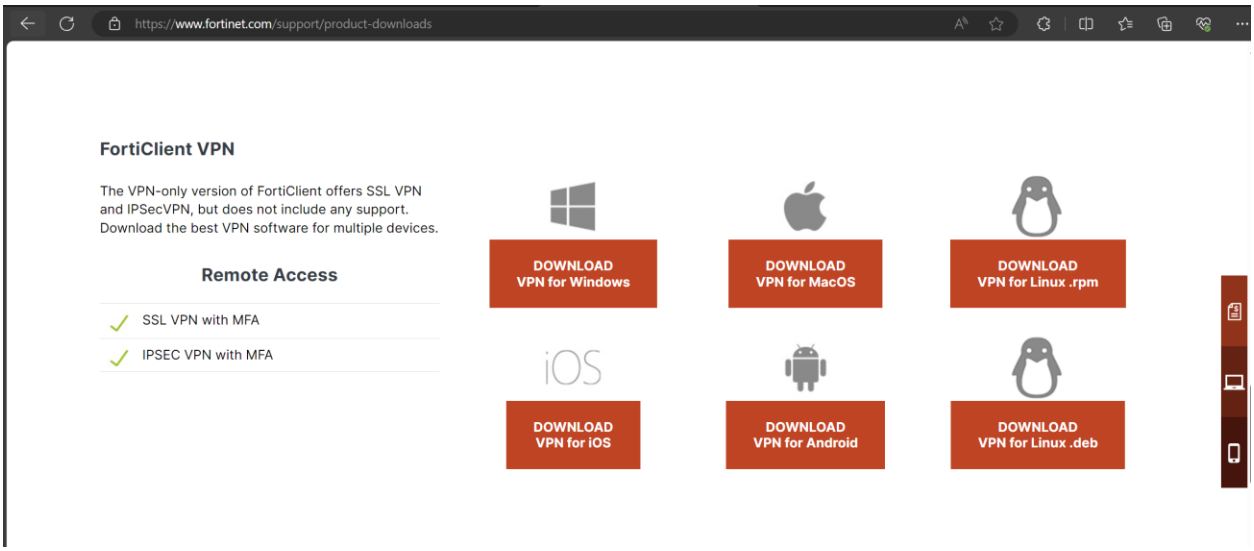
9.

Review the settings and then press Create.



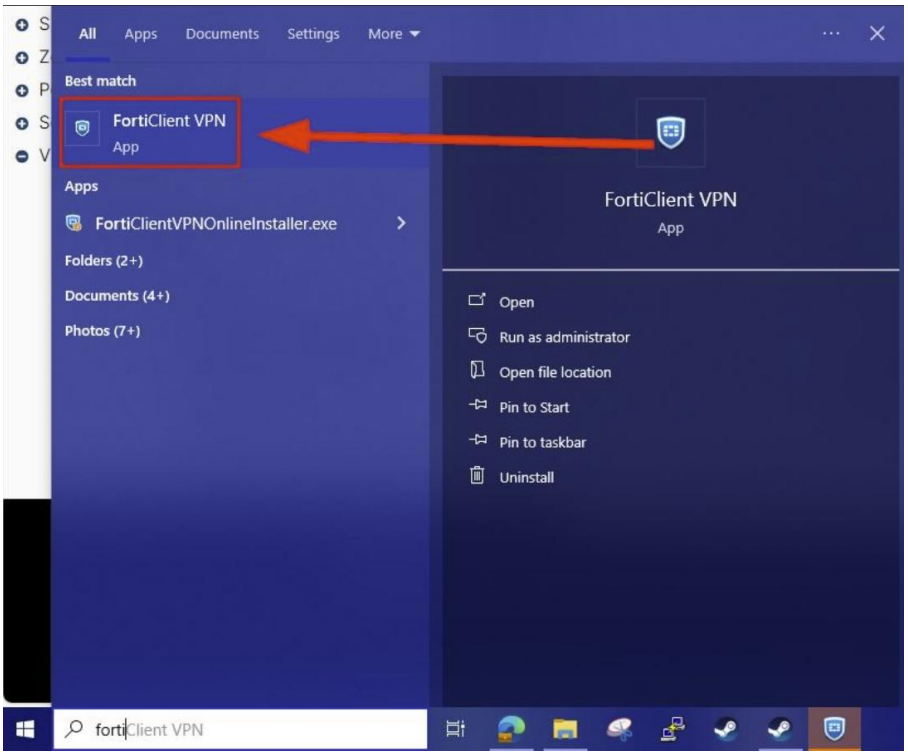
10.

Download the FortiClient VPN off the official Fortigate Website and run the installer.



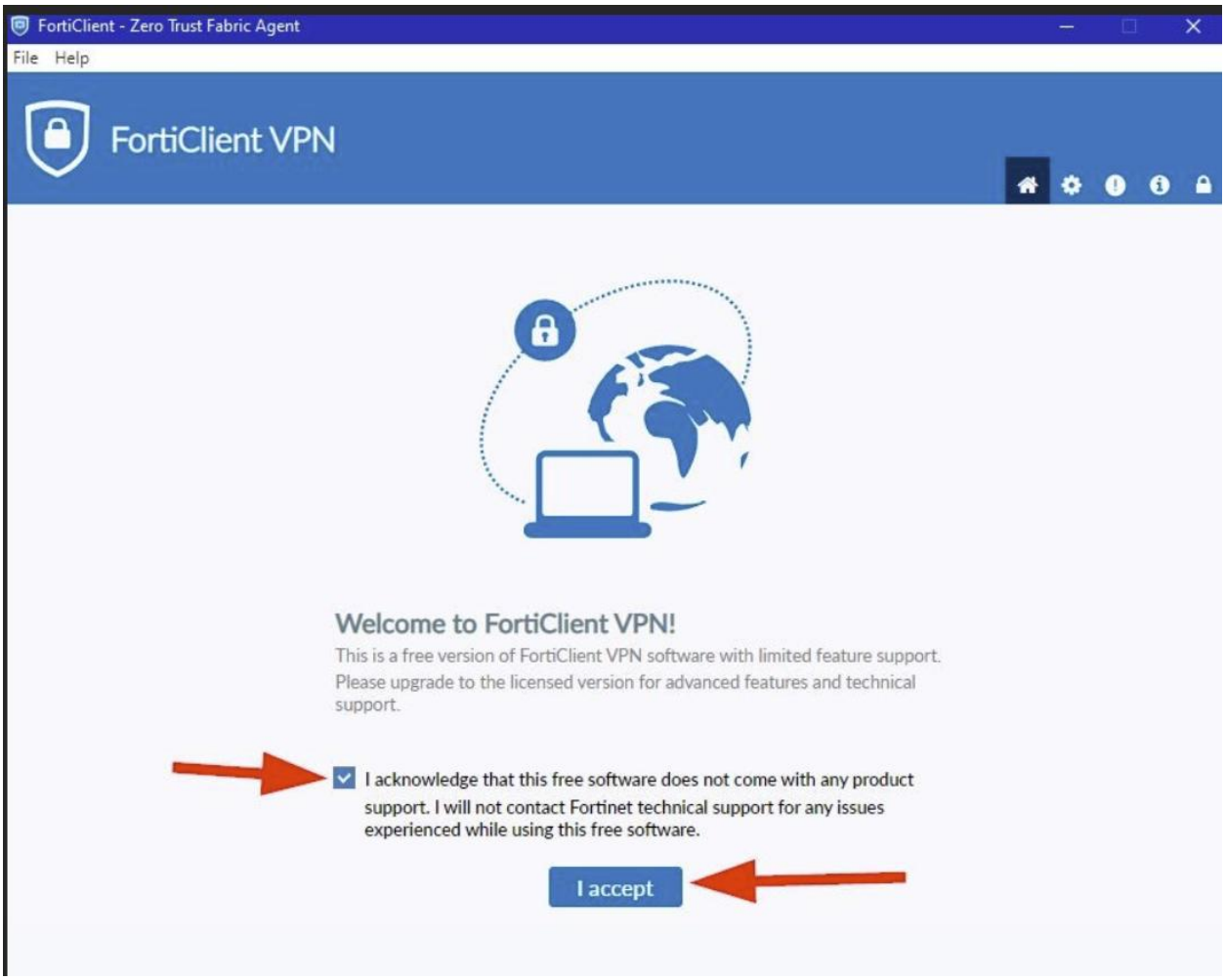
11.

Open the FortiClient VPN app after downloading.



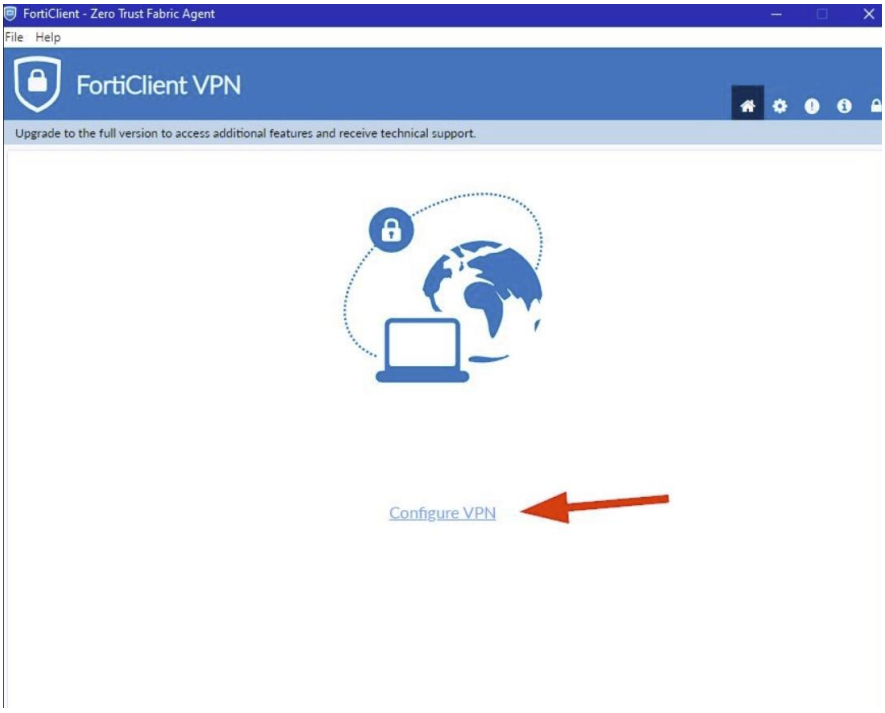
12.

Acknowledge the support notice.



13.

Press “Configure VPN” to begin the process of connecting to the internal network.

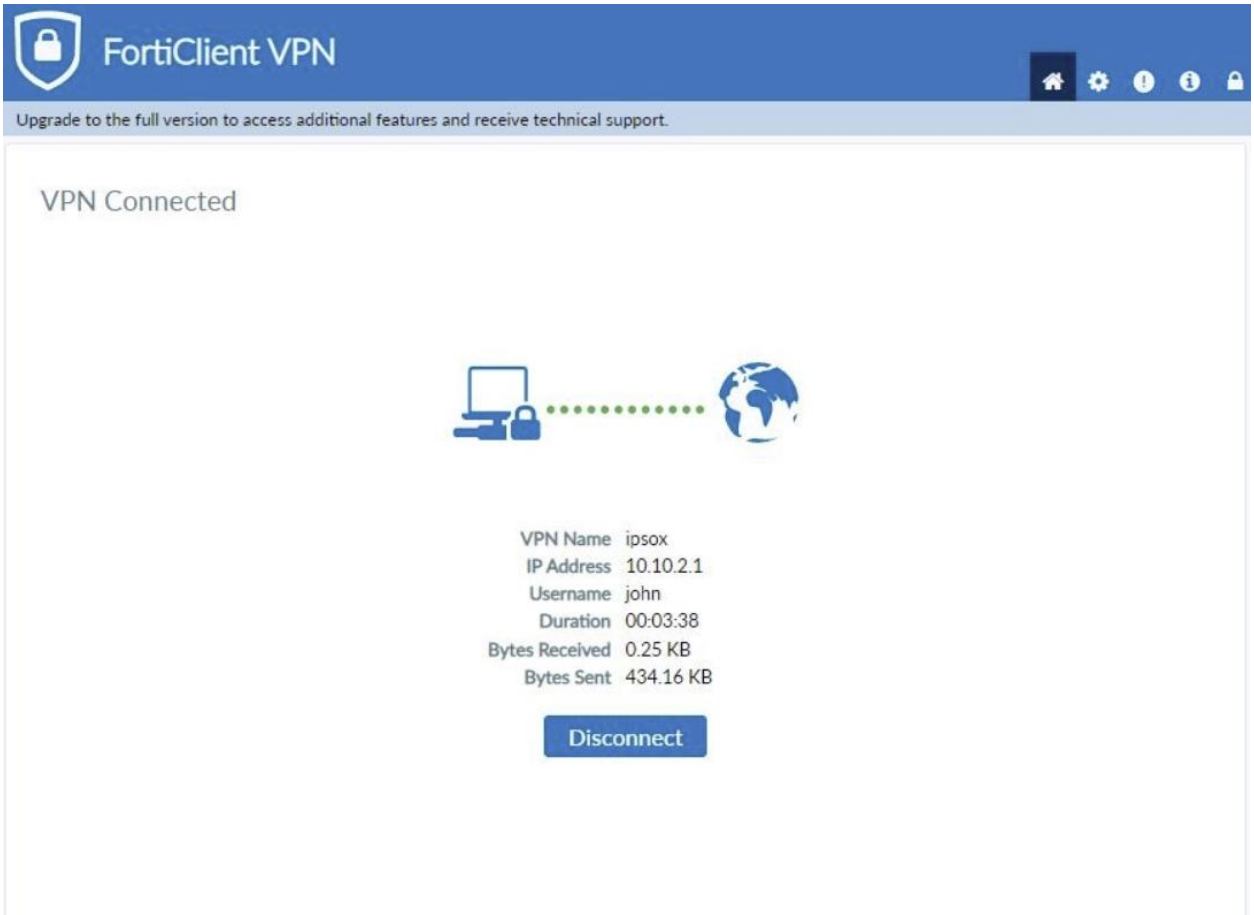

FortiClient - Zero Trust Fabric Agent
File
Help
FortiClient VPN
Upgrade to the full version to access additional features and receive technical support.
Configure VPN

14.

Create a name for the VPN connection and specify that it is an IPSEC connection. Set the Remote Gateway to the WAN port of the FortiGate firewall. Enter the preshared key previously configured and the username of a user that belongs to the VPN group. Then select Save.

15.

Wait for the VPN to connect. Verify that Bytes are being sent and recieved across the network.

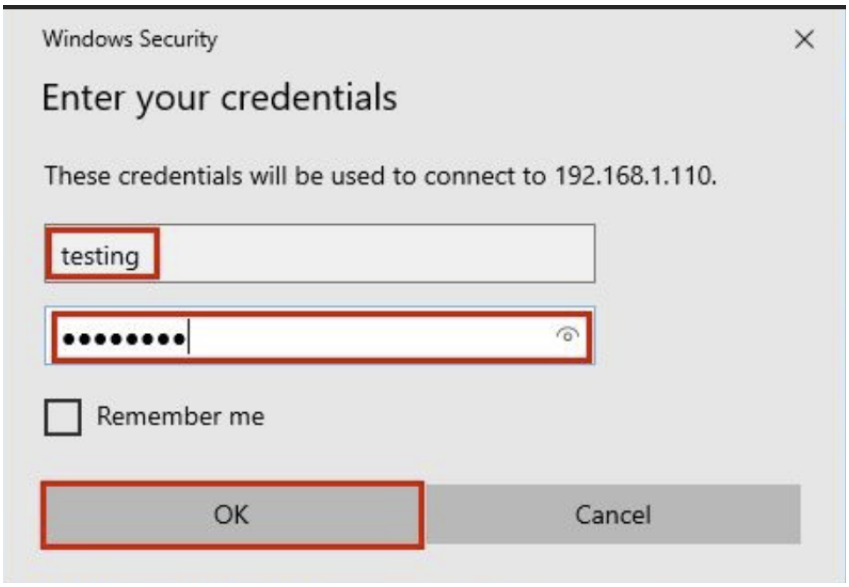


16.

Open a Remote Desktop Connection towards the destination host, specifying the destination IP.

17.

Enter the credentials of the destination user.

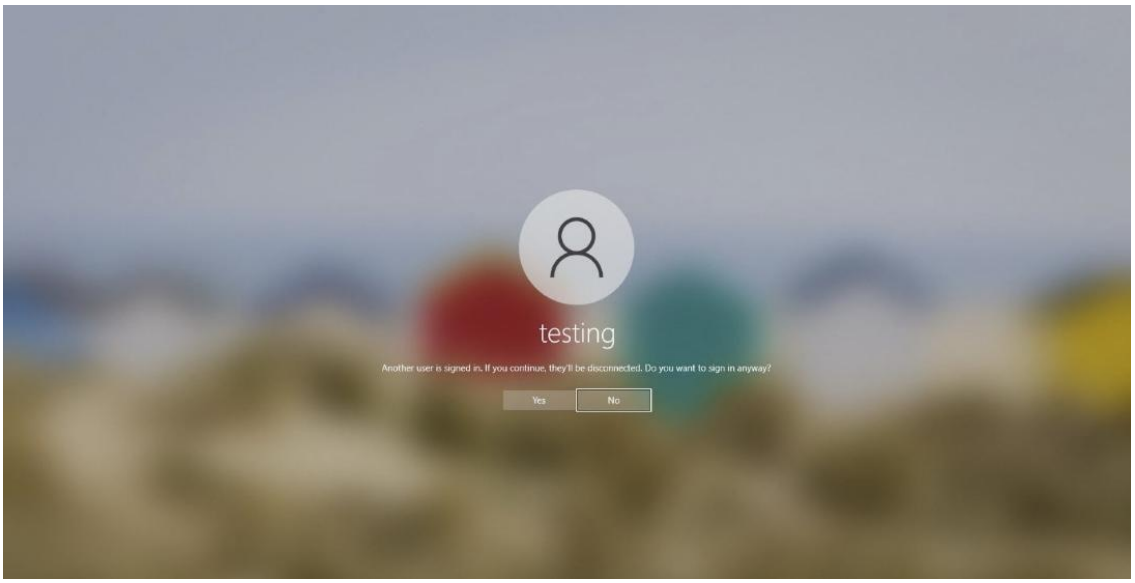


18.

An identification verification prompt should appear. Press OK and continue.

19.

Remote Desktop will then verify if you want to sign out the existing user. Press Yes and continue.



Problems

FortiGate networking issue

> Due to an unknown issue, it is impossible to set the tunnel's internal address to any private address other than 10.10.x.x 255.255.255.0. We ran into many issues when using separate IP schemes, but none of them worked until we changed to this scheme which was used as an example on the official FortiGate website.

Conclusion

IPSEC may be incredibly complicated to configure on most firewalls when the process isnt streamlined, but it is most definitely the best protocol for ensuring data is completely secure. This VPN tunneling method is extremely easy to configure on a FortiGate. The process of creating the VPN is much, much easier compared to Palo Alto's IPSEC VPN. If a tunneling protocol is needed on a FortiGate, IPSEC is most definitely the way to go, taking away one of the only downsides to using IPSEC VPNs over anything else.